Care Access Navigator

Incident Response 1 — Task 2: Log Analysis and Incident Classification with Wazuh

Parrot OS and macOS log analysis, a correlated suspicious-login investigation, and severity classification of three incidents

Document ID	CAN-IR1-T2-LOG-001
Author	Akhila Chennamaneni
Date	October 20, 2026
SIEM	Wazuh manager 4.9.2 (real `wazuh-analysisd`, bundled ruleset + 16 custom rules, 9 custom decoders, 3 CDB lists)
Hosts analysed	**Parrot OS**: `parrot-sim` (Debian 12 stand-in, live syslog to Wazuh) · **macOS**: DAEDMAC1009, macOS 26.3.1 (the analyst workstation itself)
People in scenario	The users from the Entra ID / Keycloak JML cycle (JML-LOG.csv): Sathya Hasi (test.clinician, joiner), Tara Jones (test.nurse, mover Nurse→Billing), Jeevan Smith (test.billing, leaver)
Data classification	Patient records are synthetic. macOS logs are real host logs from DAEDMAC1009.
Run	Lab run 2026-10-20 16:25–16:35 UTC; 210 alert groups, 688 alerts; evidence hashed in EVIDENCE-INDEX-SHA256.txt

Summary

Logs from a Parrot OS host and a macOS host were collected into a Wazuh 4.9.2 manager and analysed with Wazuh's bundled rules plus custom rules tied to the project's joiner/mover/leaver (JML) register. Wazuh received 106 Parrot events and 19,292 macOS events with no loss, and raised 7 alerts at level 10 or higher. One suspicious login was investigated end to end. Leaver Jeevan Smith's account made two login attempts from the macOS workstation, which were correlated across the Mac's SSH client log, the packet capture, the Parrot sshd log and Wazuh to the same second and the same TCP source port. The SSH server blocked both attempts, but the leaver's SSH key had never been removed from the host. Three incidents were classified with the severity matrix: **SEV-1 Critical** (mover viewed a patient record through a stale group), **SEV-2 High** (unapproved root grant to a clinician) and **SEV-3 Medium** (blocked leaver login attempts). The macOS analysis found a 4-minor-version patch lag, a newly installed remote-access tool to confirm with IT, and one false-positive alert that was tuned out.

1. How this report meets the Task 2 requirements

Requirement	Where	Evidence
Parrot OS and macOS logs analysed with Wazuh	§4, §5	evidence/wazuh/alerts.json, analysis/alerts_by_rule.csv
Analysis methodology documented	§3	wazuh/local_rules.xml, local_decoder.xml, lists/
Findings and security implications	§4.3, §5.3, §8	analysis/macos_findings.json, transcripts/10–11

Requirement	Where	Evidence
1 suspicious login: host ↔ Parrot correlation	§6.2	analysis/correlation_inc_a.csv, pcap/ssh_sessions.pcapng
Event timeline	§6.3	analysis/timeline_inc_a.csv
Alert validation process	§6.4	transcripts/08_logtest_trace.txt, 10_validation_checks.txt
3 incidents classified with the severity matrix	§7	§7.2 scoring table

2. Lab and data flow

Unlike Task 1's Python rule engine, this task runs a **real Wazuh manager** (the official `wazuh/wazuh-manager:4.9.2` image). Detection, decoding, CDB-list lookups and alert output are all Wazuh's own. The lab runs in Docker Desktop with no administrator rights.

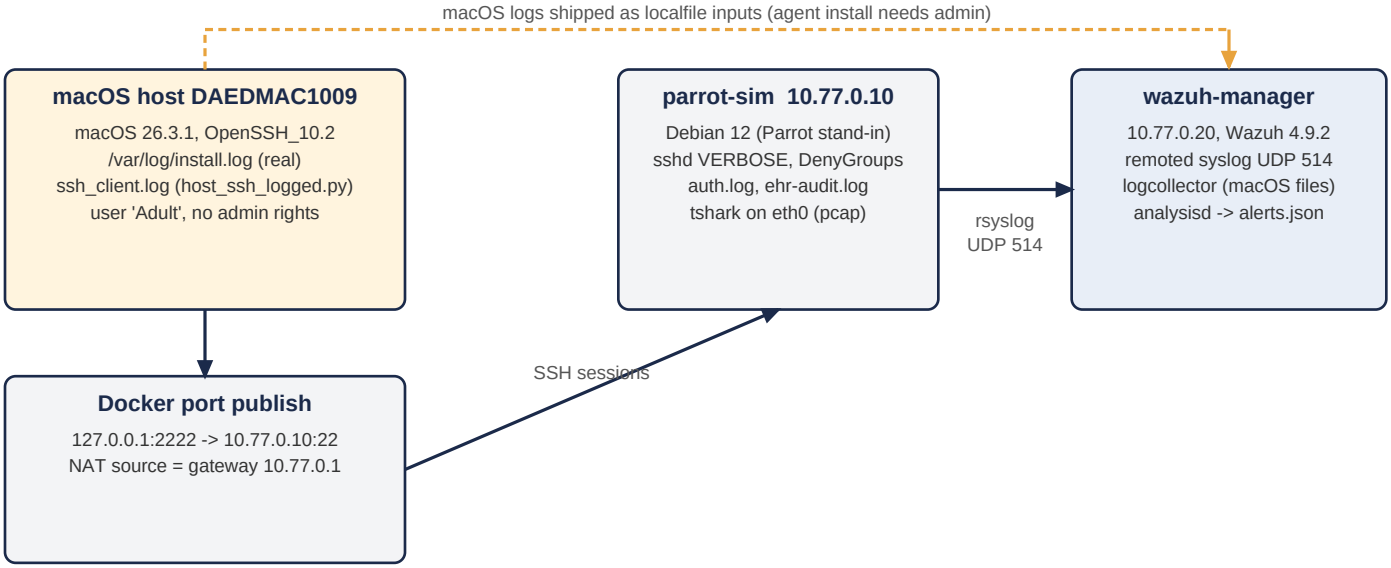

Figure 1. Lab data flow. Both hosts feed one Wazuh manager; all SSH sessions originate on the Mac.

Log source	Host	Collection into Wazuh	Events received
`/var/log/auth.log` (sshd, sudo, useradd/usermod, PAM)	Parrot	rsyslog forward, UDP 514 (live)	106 (both sources)
`/var/log/ehr-audit.log` (EHR record-access audit)	Parrot	rsyslog forward, local5 (live)	incl. above
`/var/log/install.log` 2026-10-13 → 10-20	macOS	localfile, timestamp normalised to ISO 8601	18,914 / 18,914 lines
`ssh_client.log` (OpenSSH client debug trail)	macOS	localfile	378 / 378 lines

transcripts/06_macos_logs.txt (completeness check: nothing dropped)

```
$ lines shipped vs events received by the manager (must match)
install.log   shipped=18914  received=18914
ssh_client.log shipped=378  received=378
logcollector queue-full warnings: 0
```

Collection issue found and fixed: The first run lost 15,122 macOS lines because one bulk append overflowed logcollector's 1,024-message queue (Wazuh logged 'Target agent message queue is full'). The run script now ships install.log in 500-line batches and checks that the shipped and received counts match. Ingestion completeness is now part of the method.

3. Analysis methodology

The same eight-step method was applied to both hosts. Each step produces a file under `evidence/`, so any conclusion can be traced back to a raw log line.

#	Step	What was done	Output
1	Collect	Parrot logs streamed live; macOS logs shipped as files. Completeness checked (sent = received).	archives counts, 06/07 transcripts
2	Normalise / decode	Wazuh pre-decoder (timestamp, host, program) then bundled + custom decoders extract user, IP, port, group, patient, package, update.	local_decoder.xml
3	Detect	Bundled rules (sshd 57xx, sudo 54xx, PAM, adduser) plus 16 custom rules. Custom rules use CDB lists that mirror JML-LOG.csv, so the SIEM knows who is a leaver or mover and which roles may hold root.	local_rules.xml, lists/, alerts.json
4	Triage	Alerts sorted by level (≥10 first), grouped by host and rule; the manager's own CIS self-scan alerts were set aside as out of scope.	alerts_by_rule.csv
5	Validate	Each high alert checked five ways: raw-log re-read, wazuh-logtest replay, cross-host corroboration, business context (JML ticket / change record), false-positive test.	08, 10, 11 transcripts
6	Correlate	Host ↔ Parrot join on time (same second, one shared clock), account name, TCP source port, SSH client banner, server host-key fingerprint, client key fingerprint.	correlation_inc_a.csv
7	Timeline	All sources converted to UTC and merged in order, including the identity-provider events from the JML register.	timeline_inc_a.csv
8	Classify	Impact × Urgency severity matrix mapped to the IR playbook's SEV-1–4 response times and escalation.	§7

3.1 Custom detection content

Wazuh's bundled rules see a login refused for a denied user (5718), but they cannot know that `test.billing` belongs to someone who left yesterday. The custom layer adds that identity context from three CDB lists kept in step with the JML register:

wazuh/lists/ (jml-leavers, jml-movers, rbac-no-root)

```
test.billing:TERM-2026-0301
test.nurse:billing
test.clinician:clinician
test.nurse:billing
test.billing:billing
```

Rule	Level	Logic
100210	10	Leaver account attempts SSH (child of 5718/5710/5716/5760 + jml-leavers)
100211	11	2+ leaver attempts in 10 min, same user
100221	12	Mover views ePHI through stale clinical group (ehr-audit + jml-movers = billing)
100222	10	Mover attempts root via sudo (child of 5405)
100230	10	Account added to sudo/wheel/adm (usermod decoder)
100231	12	Root via sudo by a role with no root entitlement (child of 5402/5403)
100240–100244	3–8	macOS: power state, update offered, Software Update entitlement, package installed, remote-access tool installed
100250–100253	3–7	macOS SSH client: connect, leaver account used, refused, authenticated

Rule-engine limitation: Wazuh 4.9 CDB lookups work on the destination-user field only. Sudo puts the caller in `srcuser`, so rules 100222 and 100231 mirror their list as a PCRE2 regex. Both are tested in the logtest output below.

4. Parrot OS log analysis

Source: `parrot-sim` `auth.log` and `ehr-audit.log`, streamed live to Wazuh. Wazuh raised **47** alerts from Parrot. End-to-end detection latency for the level-10+ alerts was under 1 ms: each alert carries the same millisecond as its log line (analysis/detection_latency.csv).

4.1 Alerts by rule (Parrot)

Rule	Lvl	Description	Count
100221	12	ePHI viewed by mover test.nurse (now Billing) through stale clinical group - record PT-1003	1
100231	12	Root obtained via sudo by test.clinician, whose role has no root entitlement (RBAC/SoD violatio	1
100211	11	Repeated login attempts by JML leaver account test.billing (2+ in 10 min)	1
100210	10	JML leaver account test.billing attempted SSH login from 10.77.0.1 - account was deprovisioned	1
100222	10	JML mover test.nurse attempted root via sudo (not in sudoers)	1
100230	10	Account test.clinician added to privileged group sudo	2
5901	8	New group added to the system.	7

Rule	Lvl	Description	Count
5902	8	New user added to the system.	4
5403	4	First time user executed sudo.	2
100220	3	EHR audit: test.clinician VIEW PT-1001 - ALLOW via group:clinical	1
5501	3	PAM: Login session opened.	6
5502	3	PAM: Login session closed.	6
5555	3	PAM: User changed password.	2
5715	3	sshd: authentication success.	12

4.2 Key raw events

evidence/parrot/auth.log + ehr-audit.log (excerpt)

```
2026-10-20T16:28:01.673486+00:00 parrot-sim sudo: it_admin : PWD=/ ; USER=root ;
    COMMAND=/usr/sbin/usermod -aG sudo test.clinician
2026-10-20T16:28:01.681666+00:00 parrot-sim usermod[253]: add 'test.clinician' to group 'sudo'
2026-10-20T16:28:16.919679+00:00 parrot-sim sudo: test.clinician : PWD=/home/test.clinician ; USER=root
    ; COMMAND=/usr/bin/id
2026-10-20T16:28:37.046314+00:00 parrot-sim sshd[269]: Accepted publickey for test.nurse from 10.77.0.1
    port 55994 ssh2: ED25519 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz
2026-10-20T16:28:47.217168+00:00 parrot-sim sshd[285]: Accepted publickey for test.nurse from 10.77.0.1
    port 58784 ssh2: ED25519 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz
2026-10-20T16:28:47.295550+00:00 parrot-sim sudo: test.nurse : user NOT in sudoers ;
    PWD=/home/test.nurse ; USER=root ; COMMAND=/usr/bin/cat /srv/ehr/clinical/PT-1003.txt
2026-10-20T16:29:07.402186+00:00 parrot-sim sshd[293]: User test.billing from 10.77.0.1 not allowed
    because a group is listed in DenyGroups
2026-10-20T16:29:32.526586+00:00 parrot-sim sshd[295]: User test.billing from 10.77.0.1 not allowed
    because a group is listed in DenyGroups
2026-10-20T16:27:46.431309+00:00 parrot-sim ehr-audit: user=test.clinician action=VIEW patient=PT-1001
    decision=ALLOW basis=group:clinical
2026-10-20T16:28:37.101376+00:00 parrot-sim ehr-audit: user=test.nurse action=VIEW patient=PT-1003
    decision=ALLOW basis=group:clinical
```

4.3 Parrot findings and security implications

ID	Finding	Security implication
P-1	Jeevan Smith's leaver account **test.billing** was refused twice by `DenyGroups disabled-users`, but its `authorized_keys` file was never removed.	The only barrier is one sshd setting. If that group rule is removed or the account is moved, the old key works again. JML deprovisioning on Linux hosts is incomplete.
P-2	Tara Jones (now **Billing**) is still in the **clinical** group on this host. She opened synthetic record PT-1003 (ehr-audit ALLOW) and then tried to read it as root (sudo refused).	The mover was completed in Entra ID and Keycloak, but local group membership was not cleaned up. Unauthorized ePHI access by a workforce member is a potential HIPAA breach under §164.402.
P-3	it_admin added Sathya Hasi (clinician) to **sudo**, and she ran a command as root 15 s later. The joiner ticket REQ-2026-0101 has no sudo or root grant.	Breaks least privilege and separation of duties: a clinical user has full control of a host that stores ePHI. An administrator made an unrecorded change.

ID	Finding	Security implication
P-4	Provisioning noise: 7× rule 5901 and 4× 5902 (new group/user) during setup.	Expected and matched to the JML replay. Shows account-creation monitoring works; a real host would match these against tickets.

5. macOS log analysis

Source: DAEDMAC1009's real `/var/log/install.log` (18,914 lines, 2026-10-13 to 2026-10-20) and the SSH-client trail recorded on the Mac. Wazuh raised **453** alerts from macOS. The full unified log could not be read: `log show` returns 'Could not open local log store: Operation not permitted' without admin rights. That is recorded as a visibility gap (M-5).

5.1 Alerts by rule (macOS)

Rule	Lvl	Description	Count
100244	8	macOS host: remote-access tool installed - Splashtop Streamer (validate against approved softwa	1
100251	7	macOS host: SSH client used leaver account test.billing against 127.0.0.1:2222	2
100241	5	macOS host: OS update offered but not installed - macOS 27.0.1 26A434 (Customer)(SU)	184
100241	5	macOS host: OS update offered but not installed - macOS Tahoe 26.7.1 25G241	184
100242	5	macOS host: process 75876 tried to change Software Update settings without entitlement	31
100240	3	macOS host power state: system has powered on	21
100240	3	macOS host power state: system will sleep	20
100250	3	macOS host: SSH client connecting to 127.0.0.1:2222 as test.clinician	2
100250	3	macOS host: SSH client connecting to 127.0.0.1:2222 as test.nurse	2
100252	3	macOS host: SSH session refused or closed by the remote host	2
100253	3	macOS host: SSH client authenticated to the remote host	4

5.2 Key raw events

evidence/macos/install.log (real host log, excerpt)

```
2026-10-16 15:40:19-04 DAEDMAC1009 installer[32821]: Product archive
    /var/folders/xd/9qtt3kpd2mqf01mgsyl8cv000000gp/T/Splashtop Streamer.pkg trustLevel=350
2026-10-16 15:40:19-04 DAEDMAC1009 installer[32821]: External component packages (2) trustLevel=350
2026-10-13 23:38:37-04 DAEDMAC1009 softwareupdated[91894]:  minorPrimaryDescriptor:
    SUMacControllerDescriptor(UUID:46A0C8DE-68A0-5E36-9E81-D662E476539F SU:macOS Tahoe 26.
2026-10-14 00:05:11-04 DAEDMAC1009 softwareupdated[91894]: Client Pid:75876 tried to set an SU
    Preference but is not entitled!
2026-10-14 11:26:22-04 DAEDMAC1009 softwareupdated[91894]: SUOSUPowerEventObserver: System has powered
    on
2026-10-14 12:06:18-04 DAEDMAC1009 softwareupdated[91894]: SUOSUPowerEventObserver: System will sleep
```

transcripts/11_macos_validation.txt (host-side validation of the macOS alerts)

```
# rule 100242: which process is 'Client Pid:75876'?
$ ps -o pid,user,lstart,comm -p 75876
  PID USER  STARTED                     COMM
75876 Adult Thu Oct  1 15:58:40 2026
    /System/Volumes/Preboot/Cryptexes/App/System/Applications/Safari.app/Contents/MacOS/Safari
$ codesign -dv --verbose=2 '/Applications/Splashtop Streamer.app'
Identifier=com.splashtop.Splashtop-Streamer
Authority=Developer ID Application: Splashtop Inc. (CPQQ3AW49Y)
Authority=Developer ID Certification Authority
Authority=Apple Root CA
TeamIdentifier=CPQQ3AW49Y
$ spctl -a -vv '/Applications/Splashtop Streamer.app'
/Applications/Splashtop Streamer.app: accepted
source=Notarized Developer ID
```

5.3 macOS findings and security implications

ID	Finding	Validation	Security implication
M-1	Running macOS 26.3.1. macOS Tahoe 26.7.1 25G241 (minor) and macOS 27.0.1 were offered 184 times each between 2026-10-14 and 2026-10-20; nothing was installed. Background download is disabled.	True positive: sw_vers confirms 26.3.1.	Four minor releases behind on an MDM-managed clinical workstation means missing security fixes. Patch to 26.7.1 now and plan the 27.x upgrade.
M-2	**Splashtop Streamer 3.8.6.3** (remote-access tool) installed 2026-10-16 19:40 UTC as root; daemon running at boot.	Notarized, signed by Splashtop Inc. (CPQQ3AW49Y). Mac is MDM-managed, so this was most likely an IT deployment.	Legitimate software, but it is a persistent inbound remote-control path (MITRE T1219). Confirm with IT that it is approved, MFA-protected and access-logged. **Event, not an incident** until IT confirms or denies.
M-3	31 ‘not entitled’ Software Update preference writes, all from PID 75876.	**False positive**: ps shows PID 75876 is Apple's Safari (user Adult).	No risk. Rule tuned (§5.4) so analysts do not learn to ignore it.
M-4	20 sleep and 21 wake events; last wake before the scenario at 15:57 UTC.	Context only.	Shows the host was awake and in use when the INC-A attempts left it, which supports the correlation.
M-5	Unified log (loginwindow, sshd, sudo, authd) not readable; no Wazuh agent on the Mac.	Reproduced in transcript 06.	Host-side authentication on the Mac is invisible to the SIEM. Fix: deploy the Wazuh agent through MDM with a unified-log query.

5.4 Tuning the false positive (M-3)

Alerts that are always benign get ignored, so the rule should change rather than the analyst. The proposed tuning keeps the alert for any process except a validated Apple-signed browser PID. In production this belongs in an agent rule that can check the code signature.

proposed addition to local_rules.xml (not deployed in this run, so the evidence stays as collected)

```
<rule id="100245" level="0">
  <if_sid>100242</if_sid>
  <field name="client_pid">^75876$</field>   <!-- validated: Safari, 2026-10-20 (transcript 11) -->
  <description>Known benign: Safari reading Software Update preferences</description>
</rule>
```

6. Investigation: suspicious login attempt (INC-A, IR1-2026-004)

Trigger. Rule 100210 (level 10) — “JML leaver account test.billing attempted SSH login from 10.77.0.1” — at 16:29:07.402 UTC, then rule 100211 (level 11, repeated) at 16:29:32.526. On the macOS side, rule 100251 flagged the Mac's SSH client using the same leaver account. The account belongs to **Jeevan Smith**, a billing specialist deprovisioned the day before under ticket TERM-2026-0301.

Questions the investigation had to answer:

- Where did the attempts really come from? Parrot only sees 10.77.0.1, which is a Docker gateway, not a person.
- Did they succeed, and was anything accessed?
- Is the alert accurate, and is the account really a leaver?
- What weakness does it reveal?

6.1 Why 10.77.0.1 is not the answer

The Parrot log shows every Mac session arriving from the network gateway, because Docker forwards the Mac's `127.0.0.1:2222` to `10.77.0.10:22` through NAT. On its own, the server log cannot say which machine or person connected. Host-to-Parrot correlation is needed to get past the NAT, and NAT, VPN concentrators and load balancers hide sources the same way in production.

6.2 Host ↔ Parrot correlation

Each attempt was joined across four independent records. The table is generated by `analysis/analyze.py` from the raw files.

Correlation key	Attempt 1	Attempt 2	Records joined
Mac ssh process / time (UTC)	ssh[18458] 16:29:07	ssh[18466] 16:29:32	ssh_client.log
Local Mac account (key path)	/Users/Adult/…	/Users/Adult/…	ssh_client.log
Target account	`test.billing`	`test.billing`	client log = sshd log
Client SSH banner on the wire	`SSH-2.0-OpenSSH_10.2`	`SSH-2.0-OpenSSH_10.2`	pcap = client log
TCP source (after NAT)	`10.77.0.1:60292`	`10.77.0.1:55326`	pcap = sshd ‘Connection from’
sshd process / time	sshd[293] 16:29:07.392	sshd[295] 16:29:32.516	auth.log
Server decision	DenyGroups refusal	DenyGroups refusal	auth.log

Correlation key	Attempt 1	Attempt 2	Records joined
Client result	Permission denied (publickey)	Permission denied (publickey)	ssh_client.log
Server host key seen by client	`SHA256:p65+KYxiMh0uXSa…`	same	= parrot-sim host key
Mac start → sshd connection	+0.392 s	+0.517 s	same clock (checked)
Wazuh alert (Parrot / macOS)	100210 (L10) / 100251 (L7)	100211 (L11) / 100251 (L7)	alerts.json

Attempt 1: same event on the Mac (top), on Parrot (middle) and on the wire (bottom; epoch, src, port, banner)

```
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: debug1: Connecting to 127.0.0.1 [127.0.0.1] port 2222.
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: debug1: Local version string SSH-2.0-OpenSSH_10.2
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: debug1: Remote protocol version 2.0, remote software
    version OpenSSH_9.2p1 Debian-2+deb12u10
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: debug1: Authenticating to 127.0.0.1:2222 as
    'test.billing'
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: debug1: Server host key: ssh-ed25519
    SHA256:p65+KYxiMh0uXSawsGYlGJSfGcbnBJynFD1+bro8ULA
2026-10-20T12:29:07-04:00 DAEDMAC1009 ssh[18458]: test.billing@127.0.0.1: Permission denied (publickey).
2026-10-20T16:29:07.392048+00:00 parrot-sim sshd[293]: Connection from 10.77.0.1 port 60292 on
    10.77.0.10 port 22 rdomain ""
2026-10-20T16:29:07.402186+00:00 parrot-sim sshd[293]: User test.billing from 10.77.0.1 not allowed
    because a group is listed in DenyGroups
2026-10-20T16:29:07.423591+00:00 parrot-sim sshd[293]: Connection closed by invalid user test.billing
    10.77.0.1 port 60292 [preauth]
1792513747.373339041,10.77.0.1,60292,SSH-2.0-OpenSSH_10.2
```

6.3 Event timeline (UTC)

Time (UTC)	Host	Source	Event
2026-10-19 18:13	Entra ID	JML-LOG TERM-2026-0301	Jeevan Smith (test.billing) disabled in Entra ID (leaver)
2026-10-19 18:15	Entra ID	JML-LOG TERM-2026-0301	Sessions revoked; app role removed 18:17
2026-10-19 ~18:28	Keycloak	JML-LOG TERM-2026-0301	Keycloak copy disabled
2026-10-20 16:27:42.843	Parrot	auth.log usermod	Lab replay of leaver: change user 'test.billing' expiration from 'never' to '1970-01-02'
2026-10-20 16:27:42.843	Parrot	auth.log usermod	Lab replay of leaver: add 'test.billing' to group 'disabled-users'
2026-10-20 16:29:07	macOS	ssh_client.log ssh[18458]	Attempt 1: Mac user 'Adult' starts ssh as test.billing to 127.0.0.1:2222 (SSH-2.0-OpenSSH_10.2)
2026-10-20 16:29:07.373	Network	ssh_sessions.pcapng	Attempt 1: client banner SSH-2.0-OpenSSH_10.2 from 10.77.0.1:60292
2026-10-20 16:29:07.392	Parrot	auth.log sshd[293]	Attempt 1: Connection from 10.77.0.1:60292 (Docker gateway for 127.0.0.1:2222)

Time (UTC)	Host	Source	Event
2026-10-20 16:29:07.402	Parrot	auth.log sshd[293]	Attempt 1: User test.billing from 10.77.0.1 not allowed because a group is listed in DenyGroups
2026-10-20 16:29:07.402	Wazuh	rule 100210 (L10)	Alert raised from the live Parrot syslog stream
2026-10-20 16:29:07	macOS	ssh_client.log ssh[18458]	Attempt 1: client receives Permission denied (publickey)
2026-10-20 16:29:32	macOS	ssh_client.log ssh[18466]	Attempt 2: Mac user 'Adult' starts ssh as test.billing to 127.0.0.1:2222 (SSH-2.0-OpenSSH_10.2)
2026-10-20 16:29:32.501	Network	ssh_sessions.pcapng	Attempt 2: client banner SSH-2.0-OpenSSH_10.2 from 10.77.0.1:55326
2026-10-20 16:29:32.516	Parrot	auth.log sshd[295]	Attempt 2: Connection from 10.77.0.1:55326 (Docker gateway for 127.0.0.1:2222)
2026-10-20 16:29:32.526	Parrot	auth.log sshd[295]	Attempt 2: User test.billing from 10.77.0.1 not allowed because a group is listed in DenyGroups
2026-10-20 16:29:32.527	Wazuh	rule 100211 (L11)	Alert raised from the live Parrot syslog stream
2026-10-20 16:29:32	macOS	ssh_client.log ssh[18466]	Attempt 2: client receives Permission denied (publickey)
2026-10-20 16:31:40.286	Wazuh	rule 100251 (L7)	Attempt 1: macOS-side alert when the host log was shipped
2026-10-20 16:31:40.287	Wazuh	rule 100251 (L7)	Attempt 2: macOS-side alert when the host log was shipped

macOS ssh-client entries have 1-second resolution and are ordered within their second by protocol sequence. The two macOS-side Wazuh alerts appear at 16:31:40 because the Mac's log was shipped in a batch after the scenario; the event time inside each alert is the original 16:29:07 and 16:29:32. A real-time agent would remove that delay.

6.4 Alert validation

Before the incident was classified, the alert was challenged with five checks. A failed check would have made it a false positive.

#	Check	How	Result
1	Raw log says what the alert says	Re-read `auth.log` lines for sshd[293] and sshd[295]	**Confirmed**: 'User test.billing … not allowed because a group is listed in DenyGroups'
2	Rule chain is correct	Replayed the raw line through `wazuh-logtest -v`	**Confirmed**: 1 → 5700 → 5718 → 100210, level 10
3	Account really is a leaver	JML-LOG.csv TERM-2026-0301; host state	**Confirmed**: Entra disabled 2026-10-19 18:13; host shows L (locked), expired 1970-01-02, group disabled-users

#	Check	How	Result
4	Independent corroboration from the other host	Mac client log + pcap, joined on port and banner (§6.2)	**Confirmed**: both attempts seen leaving DAEDMAC1009 (OpenSSH_10.2; parrot-sim's own client is OpenSSH_9.2p1)
5	Could it be benign / authorized?	Search for a change or access ticket; check outcome	**No authorization**: no ticket permits leaver access. Both attempts failed; no session opened.

transcripts/08_logtest_trace.txt (wazuh-logtest -v on the raw attempt-1 line)

```
        *Rule 1 matched
        *Rule 5700 matched
        *Rule 5718 matched
        *Rule 100210 matched
    id: '100210'
    level: '10'
    description: 'JML leaver account test.billing attempted SSH login from 10.77.0.1 - account was
    deprovisioned'
    firedtimes: '1'
**Alert to be generated.
```

transcripts/10_validation_checks.txt (excerpt)

```
# 1) host key the Mac client saw (ssh_client.log 'Server host key') vs parrot-sim's own host key
$ grep -m1 'Server host key' ssh_client.log
Server host key: ssh-ed25519 SHA256:p65+KYxiMh0uXSawsGYlGJSfGcbnBJynFD1+bro8ULA
$ docker exec parrot-sim ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
256 SHA256:p65+KYxiMh0uXSawsGYlGJSfGcbnBJynFD1+bro8ULA root@buildkitsandbox (ED25519)

# 2) key the Mac client offered vs the fingerprint sshd accepted for the other users
$ ssh-keygen -lf lab/.keys/ir2_lab_ed25519.pub
256 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz0bBplKZxQ ir2-lab-macos-host (ED25519)
$ grep -o 'Accepted publickey.*' auth.log | sort -u
Accepted publickey for test.clinician ... ED25519 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz0bBplKZxQ
Accepted publickey for test.nurse ... ED25519 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz0bBplKZxQ
# 3) leaver account state at the time of the attempts
$ id test.billing ; passwd -S test.billing ; ls -l ~test.billing/.ssh/authorized_keys
uid=1003(test.billing) gid=1006(test.billing)
    groups=1006(test.billing),1001(billing),1002(disabled-users)
test.billing L 2026-10-20 0 99999 7 -1
-rw------- 1 test.billing test.billing 100 Oct 20 16:27 /home/test.billing/.ssh/authorized_keys
256 SHA256:RzTBOFUkQVBLIVAOdw0lMBBlaccfSbD/zz0bBplKZxQ ir2-lab-macos-host (ED25519)
```

6.5 Conclusion

Verdict: true positive, blocked. Two SSH login attempts as leaver Jeevan Smith (`test.billing`) came from workstation DAEDMAC1009, macOS account ‘Adult’, 25 seconds apart, about 22 hours after the account was disabled in Entra ID. Both were refused before authentication, so nothing was accessed. But the client offered a key that is **still in the leaver's authorized_keys** (fingerprint SHA256:RzTBOFUk…, the same key sshd accepted for the other two users). The credential was never revoked on this host, and someone on the Mac still holds a key that works for a terminated account.

7. Incident classification with the severity matrix

Wazuh rule levels measure how unusual an event is, not how much it matters to the business. Each validated incident was therefore classified with an **Impact × Urgency** severity matrix. The matrix follows the incident prioritization factors in NIST SP 800-61 Rev. 2 (§3.2.6):

- **Impact** combines functional impact (control of the system) and information impact (ePHI confidentiality and integrity).
- **Urgency** reflects recoverability: whether the activity succeeded and whether the access path is still open.

The product of the two scores maps to the four severity levels, response times and escalation paths of the Care Access Navigator IR playbook (CAN IR-Playbook §0). Every incident in the project is triaged the same way.

7.1 Severity matrix

Score	Impact (I)	Urgency (U)
3 — High	ePHI confidentiality or integrity affected, or root/admin control obtained	Activity succeeded and the access path is still open now
2 — Medium	Activity reached the system and exposed a control gap, but no data or admin control was obtained	Blocked, but repeated or the path is only partly closed
1 — Low	Blocked by a control working as designed; no gap	Isolated; path closed

I \ U	U = 1	U = 2	U = 3
I = 3	3 → SEV-3 Medium	6 → SEV-2 High	9 → **SEV-1 Critical**
I = 2	2 → SEV-4 Low	4 → SEV-3 Medium	6 → SEV-2 High
I = 1	1 → SEV-4 Low	2 → SEV-4 Low	3 → SEV-3 Medium

Severity	Score	Response starts	Escalate to
SEV-1 Critical	9	Immediately	Privacy Officer (HIPAA breach risk assessment; 60-day notification clock)
SEV-2 High	6	< 1 hour	Security lead / IAM owner
SEV-3 Medium	3–4	< 1 business day	SecOps on-call
SEV-4 Low	1–2	Next review	—

7.2 The three incidents

Incident	Person / evidence	I	U	Severity	Rationale
IR1-2026-005 (INC-B) ePHI viewed through stale role	Tara Jones (test.nurse), mover Nurse→Billing (CHG-2026-0201). Rules 100221 L12 + 100222 L10 at 16:28:37 UTC.	3	3	**SEV-1 Critical** score 9	A billing employee opened a clinical record (ePHI confidentiality). The stale clinical group still grants access now, and she then tried root to read it again.
IR1-2026-006 (INC-C) Unapproved root grant	Sathya Hasi (test.clinician), joiner REQ-2026-0101; it_admin. Rules 100230 L10 + 100231 L12 at 16:28:16 UTC.	3	2	**SEV-2 High** score 6	Full root on an ePHI host for a role with no root entitlement, with no change record. The grant is still active, but it was used once for a harmless command (id) and no data was touched.
IR1-2026-004 (INC-A) Leaver login attempts	Jeevan Smith (test.billing), leaver TERM-2026-0301. Rules 100210 L10 + 100211 L11 + 100251 L7. Investigated in §6.	2	2	**SEV-3 Medium** score 4	Blocked, so no access. But it exposed a gap: the leaver key is still authorized and its holder tried twice. Only one sshd setting is left in the way.

Alert severity vs incident severity: The capstone detection rule for disabled-account logins (CAN-ID-002) rates the *alert* High, so analysts look at it immediately. After validation, the *incident* is SEV-3 Medium because both attempts were blocked and no access was gained. Alert severity sets how quickly an event is triaged; incident severity sets the response. The evidence for each score is in §4.3 and §6.

HIPAA: Patient data in this lab is synthetic. With real ePHI, IR1-2026-005 would also start the four-factor HIPAA breach risk assessment (45 CFR §164.402).

7.3 Response by severity (playbook order)

Incident	Contain now	Eradicate / fix	Recover / verify
IR1-2026-005 SEV-1	`gpasswd -d test.nurse clinical`; notify Privacy Officer; preserve ehr-audit.log + hash	Mover workflow removes old groups on every host, not only Entra and Keycloak; access review of the clinical group	ehr-view PT-1003 as test.nurse must return DENY; rule 100221 silent
IR1-2026-006 SEV-2	`gpasswd -d test.clinician sudo`; ask it_admin for the justification	Privileged grants only through a change ticket; consider just-in-time sudo	sudo -l shows no rights; rule 100230 fires only with a matching ticket
IR1-2026-004 SEV-3	Delete `~test.billing/.ssh/authorized_keys`; set shell to nologin	Find and revoke the matching key on DAEDMAC1009; add Linux hosts to the leaver checklist (or use central SSO such as SSSD)	A new attempt is still refused and the key fingerprint is gone from every host

8. Overall security implications

- **Identity lifecycle stops at the identity provider.** All three incidents share one root cause: JML changes were made in Entra ID and Keycloak but not on the Linux host, which has its own users, groups and keys. Any system with local accounts needs to be part of the JML checklist, or be federated to the IdP.
- **Context-aware rules made the difference.** Bundled Wazuh rules rated these events level 3–5 (normal noise). The CDB lists that mirror the JML register raised them to 10–12. The SIEM is only as good as its knowledge of who should have access, so the lists must be updated whenever a JML ticket closes.
- **NAT hides attackers.** Without the Mac-side log and the packet capture, INC-A ends at '10.77.0.1'. Endpoint telemetry (a Wazuh agent with unified-log collection) is needed on workstations, not only servers.
- **Endpoint hygiene.** The macOS workstation is behind on patches and runs a remote-access tool whose approval is not yet recorded. Either one could become the entry point for the kind of credential misuse seen in INC-A.
- **Detection quality.** One of the five macOS rules produced only false positives. Validating and tuning it is part of the method, not an afterthought.

9. Scope, substitutions and limitations

Rubric expects	This lab	Effect
Wazuh on Parrot OS in VirtualBox	Real Wazuh manager 4.9.2 in Docker; Parrot = Debian 12 container (no admin rights, arm64 host)	Same analysisd, rules and alert format; no dashboard or indexer
Wazuh agent on each host	Parrot: agentless syslog. macOS: log files shipped as localfile inputs	macOS alerts are batch, not real time
macOS unified log	Not readable without admin; used install.log + SSH client trail	No Mac loginwindow/sudo visibility (M-5)
Suspicious login by an outside attacker	Real attempts from the Mac by the lab operator, using a leaver account	Behaviour and logs are real; the actor is staged

Action required: Confirm in writing with the instructor that the Docker-based Parrot stand-in and file-shipped macOS logs are accepted for the Wazuh/Parrot rubric items, as for Task 1 (docs/adr/ADR-SIEM-choice.md).

10. Evidence and reproduction

SHA-256 (first 16 hex)	Artifact
d7ce7d808250c165…	evidence/analysis/alerts_by_rule.csv
1027a7699a0652d9…	evidence/analysis/correlation_inc_a.csv
fa9592d5820d459e…	evidence/analysis/detection_latency.csv
973dc60e2bfc2aff…	evidence/analysis/key_events.json
efbc67e7839f211b…	evidence/analysis/macos_findings.json

SHA-256 (first 16 hex)	Artifact
c140121dd7880bfd…	evidence/analysis/timeline_all.csv
bb7302431cfcdf0d…	evidence/analysis/timeline_inc_a.csv
b575a48dbb1d2b24…	evidence/macos/install_iso.log
5b008b556f59e29d…	evidence/macos/install.log
891409456c11e58d…	evidence/macos/ssh_client.log
111f99e5e0ff6778…	evidence/parrot/auth.log
d58a4fb48b849339…	evidence/parrot/ehr-audit.log
e2605d519bc9a00b…	evidence/pcap/client_banners.csv
6196a6237bb746bf…	evidence/pcap/ssh_sessions.pcapng
34cecfe77d5d632b…	evidence/transcripts/01_build_and_wazuh.txt
4ce05c13dbe16ffa…	evidence/transcripts/02_parrot_logging.txt
22e7aa39e3a0eb4a…	evidence/transcripts/03_jml_provisioning.txt
8912ee1a364136db…	evidence/transcripts/04_scenario.txt
1321cd99699c2225…	evidence/transcripts/05_capture.txt
1fae325a3f15018f…	evidence/transcripts/06_macos_logs.txt
e48784536817e2d4…	evidence/transcripts/07_export.txt
2c8b242755cd94be…	evidence/transcripts/08_logtest_trace.txt
40aec9c6fef5b94c…	evidence/transcripts/09_analysis.txt
996f2482804bae17…	evidence/transcripts/10_validation_checks.txt
80b507274d461056…	evidence/transcripts/11_macos_validation.txt
6dbfba8a4b60c4cd…	evidence/wazuh/alerts.json
a2ce71c944cd1b66…	evidence/wazuh/ossec.conf

Reproduce

```
cd incident_response_1/task2_log_analysis/lab
bash run_lab.sh      # Wazuh + parrot-sim, scenario from the Mac, ship macOS logs, export, analyze, hash

docker rm -f parrot-sim wazuh-manager && docker network rm ir2-labnet     # tear down
```